ARCHITECTURE REVIEW BRIEF

Azure Well-Architected Framework | Pre-Launch Multicloud AI Review

Prepared by: [Your Full Name]

Date: 10 October 2026 (evidence as of 20 April 2026 policy report)

Organization: National Retail Corp (Scenario)

System under review: Multicloud AI Fraud Detection Platform (FraudScore-API, FraudScore-Inference, edge inference nodes)

Review scope: Pre-launch WAF assessment ➔ all 5 pillars; evidence = Scenario_Data_Package (3 pilot incident reports, Q1 2026 GPU cost snapshot, policy/configuration status)

Primary cloud: Azure (East US 2)

Disaster Recovery environment: Amazon Web Services (AWS) ap-southeast-1, Singapore, per Policy_Configuration_Status (Legal sign-off on this region pending; the template header listed us-east-1)

Edge: Three inference nodes — Denver CO, Atlanta GA, Phoenix AZ

1. EXECUTIVE SUMMARY

Scope	Pre-launch review of the multicloud AI fraud-detection platform (Azure East US 2, AWS DR, three edge nodes) against all five Azure WAF pillars, using three pilot outages, the Q1 GPU cost snapshot and the 20 Apr 2026 policy report, ahead of the fixed Q3 launch.
Top 3 Risks	**1.** Write-capable storage SAS token hard-coded in Git ➔ Security ➔ High **2.** DR failover is manual and the Singapore DR region lacks Legal sign-off ➔ Reliability ➔ High **3.** AWS DR security groups open to the internet (SSH, 443) ➔ Security ➔ High
Priority Action	Rotate the exposed SAS token now and replace it with Managed Identity + RBAC on the fraud-models storage account (SecOps; Rank 1).
Cost / Schedule Impact	Rank 1 needs ~2–3 engineer-days and no platform freeze. The Top 5 fit the 4-engineer team and ≤4-week freeze limit, except a 4–6-week DR re-region if Legal rejects Singapore. Rank 5 saves an estimated $18K–$22K/quarter against the $34,421 Q1 overrun.

2. WAF FINDINGS BY PILLAR

PILLAR 1: RELIABILITY — FINDING 1

Finding

Recovery depends on manual action: no automated DR failover (AWS DR was healthy but unused in INC-001), no automated edge-model drift detection (INC-003), and the Singapore DR region has no Legal sign-off (Gap 5).

Evidence

INC-001 (12 Mar): 23-min outage, 100% of scoring requests dropped (~3,400 txns; 3 over $50,000 unscored). AWS DR healthy at 14:31, but failover needed Tech Lead approval (not on call); no failover policy, owner unassigned. INC-003 (18 Apr): sync script returned exit 0 on failure; edge nodes ran stale v2.1.3 for 7 h undetected, ~103 false positives. Gap 5: Legal sign-off on Singapore DR pending at 20 Apr; re-region = 4–6 weeks. Baseline diagram also shows single-region Redis — no incident evidence (unvalidated).

Severity

High

Confidence

High — direct incident timelines (Redis point is diagram-only: Medium).

Impact if Unresolved

A repeat leaves fraud scoring dark until an approver is found, and a Singapore failover could itself breach residency rules; stale edge models cause silent false-positive spikes.

Diagram Callout #

Callout 1 (DR inference endpoint; edge zone)

Remediation Idea

Obtain the Gap 5 decision (escalate to the CTO), then configure health-probe-driven failover to the approved DR region (Azure Front Door or Traffic Manager) with a rehearsed runbook and pre-authorised trigger rights; add checksum-validated edge sync with version reporting.

Effort Band

Significant >2w (design starts in parallel; build follows the Gap 5 decision)

Success Metric

Failover drill: traffic shifts in ≤5 min with no manual approval (INC-001: 23 min); edge drift alert in <15 min (INC-003: 7 h). Targets proposed.

Compliance Link

Data residency (internal policy; GDPR Art. 46 if EU cardholder data in scope) — Legal pending. SOC 2 A1.2 / A1.3.

PILLAR 2: SECURITY — FINDING 2A

Finding

A write-capable SAS token for the fraud-models storage account is hard-coded in deployment YAML in Git, and a Cognitive Services key sits outside Key Vault.

Evidence

Policy report Gap 3: fraud-data-connector-svc holds a connection string with SAS token in Git commit 7a3f2c1 (3 Apr), expiry 31 Dec 2026, write access to fraud-models; fraud-enrichment-svc holds COGNITIVE_SERVICES_KEY as an env var (2 of 4 services). Rated "CRITICAL — rotate immediately". Edge nodes pull production models from this storage (INC-003).

Severity

High (Critical per policy report)

Confidence

High — direct configuration evidence (kubectl review 18 Apr; Git commit).

Impact if Unresolved

Anyone with repository read access can overwrite the production model that scores every transaction and feeds the edge nodes — a route to tampering with fraud decisions.

Diagram Callout

Callout 2A (Model data store)

Remediation Idea

Rotate the exposed SAS token immediately, purge it from Git history (git filter-repo), and replace it with Managed Identity + RBAC on the fraud-models storage account; move the Cognitive Services key to Key Vault.

Effort Band

Quick win <2d (rotation <1 d; full clean-up 2–3 d per report)

Success Metric

Old SAS revoked; repo and pod-spec secret scan = 0 findings; 4 of 4 services on Key Vault / Managed Identity (today 2 of 4).

Compliance Link

PCI DSS v4.0 Req 8.6.2 (reviewer mapping); ASB IM-8; SOC 2 CC6.1.

PILLAR 2: SECURITY — FINDING 2B

Finding

The AWS DR environment and Azure AI-service traffic are exposed to the public internet: SSH and 443 are open to 0.0.0.0/0 on AWS DR, and AKS reaches Azure AI services without Private Endpoints.

Evidence

Gap 4: AWS DR inbound 0.0.0.0/0 on TCP/22 and TCP/443; Azure→AWS traffic crosses the public internet; AWS owner unassigned; outside Azure Policy. (Baseline diagram draws a VPN/Transit link — to be confirmed.) Gap 2: AKS reaches Azure OpenAI / Cognitive Services over public endpoints; no Private Endpoint, NSG egress rule or Azure Firewall. Policy compliance 67% vs 90% target.

Severity

High

Confidence

High on configuration; Medium on the actual cross-cloud path (diagram vs report).

Impact if Unresolved

Open SSH on DR instances is a standing intrusion path into the environment that must carry traffic during an outage; PII-bearing scoring traffic leaves the Azure backbone.

Diagram Callout

Callout 2B (DR inference endpoint; Network perimeter)

Remediation Idea

Remove inbound 0.0.0.0/0 TCP/22 on the AWS DR security groups, replace it with AWS Systems Manager Session Manager and name an AWS environment owner; then restrict TCP/443 to Azure egress IPs and add Private Endpoints for Azure OpenAI and Cognitive Services.

Effort Band

Quick win <2d (SSH); Moderate 1–2w (443 + Private Endpoints)

Success Metric

Port 22 closed and 443 allow-listed on DR instances; 0 public endpoints on AI services; Azure Policy compliance ≥90%.

Compliance Link

PCI DSS v4.0 Req 1.3 (per policy report); SOC 2 CC6.6; ASB NS-3 / NS-7. AWS: principle applies; AWS-native tooling differs.

PILLAR 3: COST OPTIMIZATION — FINDING 3

Finding

GPU spend ran 40.5% over budget because A100 clusters are never deallocated, nothing autoscales, and no Spot or reserved capacity is used.

Evidence

GPU cost snapshot Q1 2026: $119,421 actual vs $85,000 budget (+ $34,421). A100 batch retraining +$19,840 (23% average utilization, idle 18–20 h/day) and A100 offline scoring +$6,420 (34%) are 76% of the overage; real-time T4 endpoint +$7,720 (8% utilization 00:00–06:00, no scale-to-zero). AWS DR adds $2,100/month (24/7), outside the Azure budget.

Severity

Medium

Confidence

High on spend; Medium on savings (snapshot quotes $15K–$18K/quarter and $19K–$22K/year for the same action).

Impact if Unresolved

The pilot already overspends by ~$11K a month; at production scale idle A100 hours compound and consume budget needed for the risk fixes.

Diagram Callout

Callout 3 (GPU inference cluster; Batch inference scheduler)

Remediation Idea

Enable idle auto-deallocation (idleSecondsBeforeScaleDown=300) on the A100 clusters and autoscaling on the managed online endpoint (minReplicas=1 overnight, scale out at GPU >70%); next, move batch retraining to Spot NCasT4_v3 and reserve the 4 inference T4 nodes for 1 year.

Effort Band

Quick win <2d (Spot migration 2–3 w follows)

Success Metric

A100 idle <1 h/day; Q2 GPU overage cut from +40.5% to ≤+20% (est. $18K–$22K/quarter from these two changes).

Compliance Link

None

PILLAR 4: OPERATIONAL EXCELLENCE — FINDING 4

Finding

No runbooks, escalation path, blameless postmortem or change control exist, and AKS / AML audit logs are not retained — incidents are resolved ad hoc and cannot be reconstructed.

Evidence

INC-002 (1 Apr): alert 10:14, engineer reached 10:31 via an unmonitored Slack channel (17 min); no runbook; informal write-up. INC-001: email-only alerting. INC-003: Security changed the Blob firewall without telling Platform; no change process; edge IPs not in IaC. Gap 6: AKS kube-audit and AML endpoint logs not retained — scoring activity "not reconstructable". Edge nodes and AWS DR sit outside Azure Policy (no Azure Arc).

Severity

High

Confidence

High — three incident timelines plus Gap 6 configuration.

Impact if Unresolved

Improvised response prolongs every fault (report extrapolates $8,200 to $82,000+ per incident at production volume), and the missing audit trail is a direct PCI DSS Req 10 failure.

Diagram Callout

Callout 4 (Monitoring)

Remediation Idea

Route AKS and AML endpoint logs to Log Analytics (365-day retention) and publish a P1/P2 runbook, paging-based escalation matrix and blameless postmortem process; require change approval for storage-firewall rules.

Effort Band

Moderate 1–2w (log settings 2–3 d; runbooks and paging cross-team)

Success Metric

Logs retained 365 days; time to reach a responder <5 min (INC-002: 17 min); postmortem for every P1/P2; 0 untracked firewall changes.

Compliance Link

PCI DSS v4.0 Req 10 (policy report cites 10.7); ASB LT-3; SOC 2 CC7.2–CC7.4, CC8.1.

PILLAR 5: PERFORMANCE EFFICIENCY — FINDING 5

Finding

Real-time inference and batch retraining share one A100 pool with no workload isolation or autoscaling, so a background job saturated the GPUs during the Black-Friday-scale load test.

Evidence

INC-002: at 800 req/min GPU hit 100% by 10:09 while retraining job FraudModel-Retrain-v2.2.1 (running since 09:45) shared the 2×A100 pool; p95 178 ms → 4,200 ms peak; 12% HTTP 429 (~3,840 requests); recovered only after a manual pause at 10:35. No autoscaling or isolation. Note: the cost snapshot puts the endpoint on 4×T4 while INC-002 uses the A100 pool — confirm before resizing.

Severity

Medium

Confidence

High on contention (timeline); Medium on right-sizing (sources disagree on GPU class).

Impact if Unresolved

Launch-day peaks could drop ~12% of scoring calls to a competing job — missed fraud checks ($8,200 in the test; report extrapolates $82,000+ at 10× volume).

Diagram Callout

Callout 5 (GPU inference cluster; Batch inference scheduler)

Remediation Idea

Split the GPU pools — real-time inference on its own autoscaled pool, retraining and offline scoring on separate schedulable pools — and repeat the 800 req/min load test with queue depth or GPU >70% as the scale-out trigger.

Effort Band

Moderate 1–2w

Success Metric

Re-test at 800 req/min with batch jobs running: p95 <250 ms, 0% HTTP 429. Target proposed.

Compliance Link

None (supports SOC 2 A1.1 capacity)

3. PRIORITIZED REMEDIATION ROADMAP → TOP 5 ACTIONS

Rank	Action	WAF Pillar	Owner Role	Effort	Timeline	Acceptance Criteria
1	Rotate the exposed SAS token immediately, purge it from Git history (git filter-repo), and replace it with Managed Identity + RBAC on the fraud-models storage account; move the Cognitive Services key to Key Vault.	Security (2A)	SecOps (AppTeam fixes the YAML)	<2d	Sprint 1, Week 1	Old SAS revoked; secret scan of repo and pod specs returns 0 findings.
2	Remove inbound 0.0.0.0/0 TCP/22 on the AWS DR security groups, replace it with AWS Systems Manager Session Manager and name an AWS environment owner.	Security (2B)	InfraOps	<2d	Sprint 1, Week 1	External scan shows port 22 closed; Session Manager access verified; owner named.
3	Obtain the Gap 5 decision (escalate to the CTO), then configure health-probe-driven failover to the approved DR region with a rehearsed runbook.	Reliability (1)	Platform (Legal and CTO decision gate)	>2w	Escalate Week 1; design Sprint 1–2; drill before the launch gate (a re-region adds 4–6 weeks, so start on the decision)	Written Legal decision on file; failover drill moves traffic in ≤5 min with no manual approval.
4	Route AKS and AML endpoint logs to Log Analytics (365-day retention) and publish a P1/P2 runbook, paging-based escalation matrix and blameless postmortem process.	Operational Excellence (4)	Platform (SecOps co-owns logging)	1–2w	Sprint 1–2	Logs queryable for 12 months; INC-002 tabletop reaches a responder in <5 min.
5	Enable idle auto-deallocation (idleSecondsBeforeScaleDown=300) on the A100 clusters and autoscaling on the managed online endpoint.	Cost Optimization (3); also Performance Efficiency (5)	Platform	<2d	Sprint 1, Week 2	A100 idle <1 h/day; load test confirms scale-out at GPU >70%.

Prioritization Rationale: Impact vs. Effort

	LOW EFFORT	HIGH EFFORT
HIGH IMPACT	**Do First (Rank 1–2)** High impact, quick to implement ➔ must not be left below Rank 2 **Rank 1 (SAS token), Rank 2 (AWS public SSH): impact 5, effort 1 each.**	**Plan (Rank 3–4)** Worth the effort ➔ schedule for sprint after launch **Rank 3 (DR failover + Gap 5), Rank 4 (audit logging + runbooks): impact 5 and 4, effort 5 and 3.**
LOW IMPACT	**Consider (Rank 5)** Quick but marginal ➔ only if capacity allows **Rank 5 (GPU idle/autoscale): impact 3, effort 1.**	**Defer / Drop** Do not include in top 5 **Spot migration for batch retraining (impact 3, effort 3) — queued after Rank 5.**

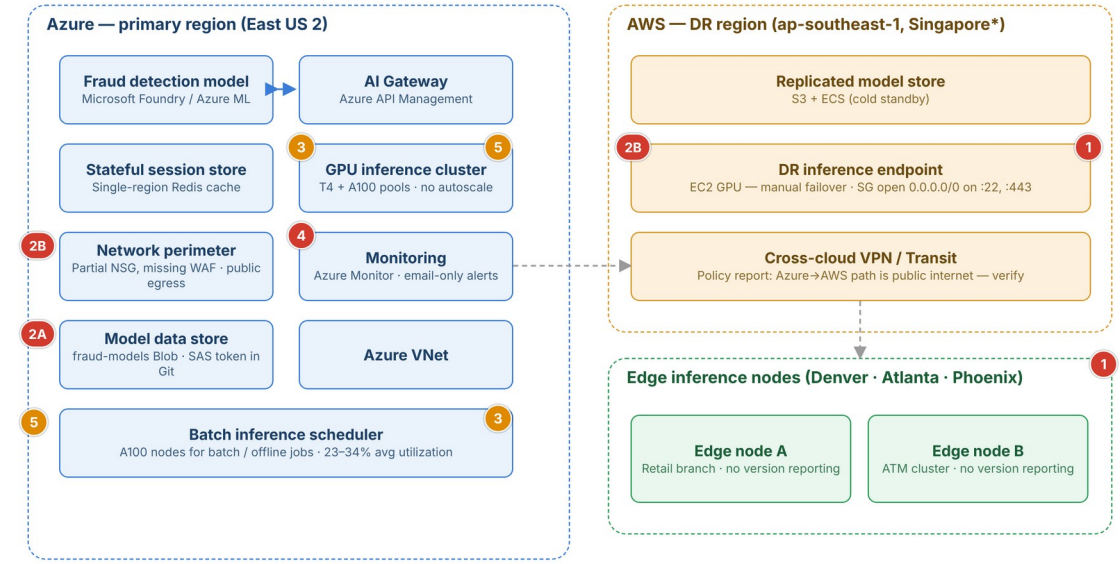
Prioritization narrative (Prompt 3): Rank 1 is the exposed write-capable SAS token: it is the item the policy report marks "CRITICAL — rotate immediately", it lets anyone with repository access tamper with the production model that scores every transaction and feeds the edge nodes, and it costs about 2–3 engineer-days with no platform freeze, so it buys the most risk reduction per unit of effort before the fixed Q3 launch. Rank 2 (closing public SSH on the AWS DR) is equally cheap; Ranks 3–4 are the heavier, Legal-gated DR work and the operations controls that must be sequenced across the 4-engineer team and inside the 4-week freeze limit; Rank 5 recovers an estimated $18K–$22K per quarter of GPU overspend with a <2-day configuration change.

Sequenced next (outside the Top 5): Private Endpoints and AWS 443 restriction (Moderate, Finding 2B); GPU pool isolation and load re-test (Moderate, Finding 5); customer-managed key on fraud-models (<1 day, Gap 1 — add to Sprint 1 if capacity allows); edge sync fix and version reporting (folded into Rank 3); Spot migration and 1-year T4 reservations (after Rank 5). Capacity check: Ranks 1, 2 and 5 total ~5–6 engineer-days in Sprint 1, leaving the 4-engineer team free to start Ranks 3 and 4; scoring in Appendix D.

4. ANNOTATED ARCHITECTURE DIAGRAM

Annotated Architecture Diagram — Multicloud AI Fraud Detection Platform

Azure Well-Architected Framework pre-launch review · numbered callouts map to Brief Section 2 findings · evidence: Scenario_Data_Package



Callout colour = severity: Red — High · Amber — Medium · Blue — Low **Effort:** QUICK WIN <2 days · MODERATE 1–2 weeks · SIGNIFICANT >2 weeks

Callout legend — WAF risk locations

1 **Reliability** · High severity — Recovery depends on people: AWS DR was healthy but unused in INC-001 (23-min outage, ~3,400 txns unscored); edge model drift ran 7 h undetected (INC-003); Singapore DR region still under legal review (Gap 5). — SIG >2w

2A **Security** · High severity — Write-capable SAS token for fraud-models storage hard-coded in Git (commit 7a3f2c1, expires 31 Dec 2026); Cognitive Services key outside Key Vault (Gap 3). — QUICK WIN <2d

2B **Security** · High severity — Public exposure: AWS DR security groups open to 0.0.0.0/0 on TCP/22 and 443; AKS→Azure OpenAI / Cognitive Services over public endpoints, no Private Endpoint (Gaps 4, 2). — QUICK WIN → MOD

3 **Cost Optimization** · Medium severity — Q1 GPU spend $119,421 vs $85,000 budget (+40.5%); A100 clusters idle 18–20 h/day with no auto-deallocation or Spot; endpoint T4 nodes run 24/7. — QUICK WIN <2d

4 **Operational Excellence** · High severity — No runbook, escalation matrix or blameless postmortem (INC-002: 17 min to reach an engineer); AKS / AML diagnostic logs not routed — PCI DSS Req 10 gap (Gap 6). — MODERATE 1–2w

5 **Performance Efficiency** · Medium severity — Retraining job and real-time endpoint share one A100 pool; at 800 req/min p95 went 178 ms → 4,200 ms and 12% of requests returned HTTP 429 (INC-002). — MODERATE 1–2w

Notes. (1) Same callout number on several components marks the same finding in more than one place. (2) Baseline labels "ND-series" and "H100" were relabelled to the SKUs in the evidence (NCasT4_v3, NC24ads_A100_v4); the package contains no H100 or ND-series nodes. (3) *Template header lists AWS us-east-1; the Policy report places DR in ap-southeast-1 and Legal sign-off on that region was PENDING at 20 Apr 2026 (Gap 5) — treated as an open risk, not resolved. (4) The baseline Redis session store is single-region but no incident evidence implicates it; carried as an unvalidated observation under Finding 1. (5) AWS components are reviewed here through the Azure WAF lens only; a real engagement would assess them against the AWS Well-Architected Framework (principle applies; AWS-native tooling differs).

Diagram Legend

Red callout	High severity	**Amber callout**	Medium severity	**Blue callout**	Low severity
Quick win	<2 days effort	**Moderate**	1–2 weeks effort	**Significant**	>2 weeks effort

Appendix A: Incident Report Summaries

Incident	Date	Symptom	Suspected Root Cause	WAF Pillar
INC-001	12 Mar 2026	23-minute total outage of FraudScore-API (14:23–14:46 UTC); all pods CrashLoopBackOff; ~3,400 txns unscored; healthy AWS DR not used	OOM kill (4Gi limit vs 4.1Gi; model grew 1.4→2.3 GB); CPU-only HPA; no automated DR failover, owner unassigned. Partial.	Reliability
INC-002	1 Apr 2026	41-minute latency degradation in 800 req/min load test: p95 178→4,200 ms, 12% HTTP 429; 17 min to reach an engineer; no runbook	Retraining job (09:45 UTC) shares the A100 pool with the real-time endpoint; no autoscaling, runbook, escalation matrix or postmortem. Partial.	Operational Excellence (also Cost, Performance)
INC-003	18 Apr 2026	67-minute quality degradation: three edge nodes on stale model v2.1.3, false positives +8.3%, ~103 mis-flagged txns, ~23 escalations (est.)	Blob firewall rule (17 Apr 22:17 UTC) blocked edge IPs; sync script returns exit 0 on failure; no version reporting or change control. Partial.	Reliability (also Operational Excellence, Security)

Data notes: INC-002 states "47 minutes" from first alert to resolution; its timeline gives 21 min to the job pause (10:14→10:35) and 29 min to recovery (10:43). INC-003 states ~9 h of mismatch; timestamps give ~10 h 18 min. This brief uses the timestamps.

Appendix B: Graphics Processing Unit (A specialized electronic circuit designed to accelerate computation, commonly used for AI inference and machine learning workloads.) Cost Snapshot

Period	Budget	Actual
Q1 2026 (1 Jan–31 Mar) — total GPU	**$85,000**	**$119,421 (+$34,421; +40.5% overrun)**
A100 batch retraining	$28,000	$47,840 (+$19,840)
A100 offline scoring	$8,200	$14,620 (+$6,420)
T4 real-time inference	$31,200	$38,920 (+$7,720)
Edge + dev/test	$17,600	$18,041 (+$441)

Appendix C: Policy / Configuration Status Summary

Azure Policy compliance 67% (target 90% before Q3 launch); report dated 20 Apr 2026; edge nodes excluded from Azure Policy scope.

Gap 1 Encryption (NON-COMPLIANT): fraud-models storage (prod, staging, archive) on Microsoft-managed keys; policy 6fac406b-40ca-413b-bf8e-0bf964659c25, ASB DP-5. <1 day; Sprint 1 if capacity allows.

Gap 2 Network segmentation (NON-COMPLIANT): AKS to Azure OpenAI / Cognitive Services over public endpoints; policy 2e80a7ec-ac58-48ba-8a6e-a1a46f4e5394, ASB NS-3 / NS-7. 1–2 weeks; Finding 2B.

Gap 3 Secrets (NON-COMPLIANT, CRITICAL): SAS token in Git commit 7a3f2c1; Cognitive Services key as env var; ASB IM-8. Rank 1.

Gap 4 AWS DR exposure (AT RISK): 0.0.0.0/0 on TCP/22 and 443; public inter-cloud path; outside Azure Policy; owner unassigned. Rank 2.

Gap 5 Data residency (UNDER REVIEW — not resolved): Singapore DR vs CONUS primary; Legal review opened 28 Mar 2026, sign-off pending at 20 Apr (estimated 15 May); escalate to the CTO if unanswered. Re-region (Option B) 4–6 weeks. Rank 3.

Gap 6 Audit logging (NON-COMPLIANT): AKS kube-audit and AML endpoint logs not retained; two AKS / App Service diagnostic-log policies, ASB LT-3, PCI DSS Req 10. Rank 4.

Appendix D: Prioritization Scoring

Impact 1–5 (5 = removes a launch-blocking security, compliance or availability risk; 3 = cost or contained operational risk); Effort 1–5 (1 <2 d, 2 2–5 d, 3 1–2 w, 4 2–4 w, 5 >4 w or externally gated). Order = template quadrant, then impact, then impact ÷ effort. Scores (impact, effort): SAS rotation 5,1 (Rank 1); AWS public SSH 5,1 (2); DR failover + Gap 5 5,5 (3); audit logging + runbooks 4,3 — touches all 3 incidents and PCI Req 10 (4); A100 deallocation + endpoint autoscale 3,1 (5); Private Endpoints + AWS 443 4,3 (next); GPU pool isolation 4,3 (next); edge sync fix 3,2 (in Rank 3); CMK on fraud-models 2,1 (Sprint 1 if capacity); Spot for batch 3,3 (after Rank 5).

Framework alignment and sources:

1. Azure Well-Architected Framework 2026 and Azure Well-Architected Review (learn.microsoft.com/en-us/azure/well-architected; /assessments/azure-architecture-review); Azure compliance — PCI DSS and SOC 2 Type II (learn.microsoft.com/en-us/azure/compliance). PCI DSS v4.0 and SOC 2 criteria are reviewer-mapped where the policy report gives none.
2. Effort bands (Quick win / Moderate / Significant) are course-defined; Azure Advisor uses High/Medium/Low impact categories.
3. Evidence: Scenario_Data_Package.zip (README, INC-2026-0312-001, INC-2026-0401-002, INC-2026-0418-003, GPU_Cost_Snapshot_Q1_2026.csv, Policy_Configuration_Status.txt); Azure_Well_Architected_Framework_Summary.docx.
4. AWS DR components are reviewed through the Azure WAF lens only; a real engagement would assess them against the AWS Well-Architected Framework (principle applies; AWS-native tooling differs).